

T3 Connect Control Plane and Managed Endpoint Flow

T3 Connect links a locally authorized T3 environment to a signed-in cloud user, provisions a managed HTTPS/WSS endpoint, and brokers proof-bound remote connections. The environment remains the access authority; the relay coordinates identity, endpoint lifecycle, and notifications.

Security Invariant

Cloud identity alone is not an environment login. Remote access requires:

- a Clerk-authenticated T3 Connect user;
- an active user/environment relay link;
- a DPOP private key held by the remote client;
- a relay-signed mint request accepted locally; and
- an environment token bound to the client's DPOP key.

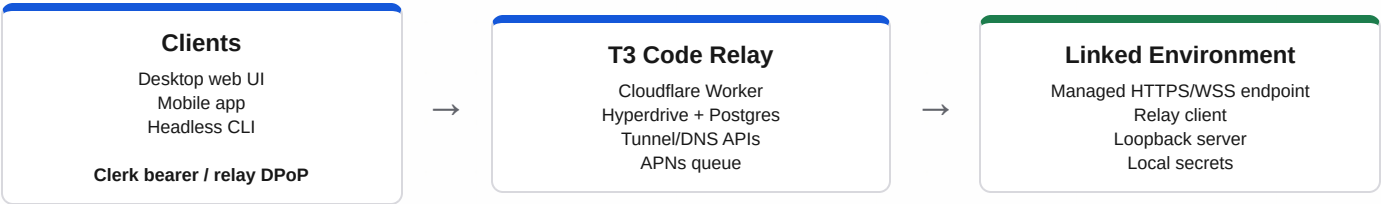
The relay cannot mint an environment access token by itself. The local environment issues the bootstrap credential and final access token.

Trust Boundaries

- **Clerk:** user identity and OAuth/PKCE.
- **Relay Worker:** links, endpoint allocations, proofs, and notifications.
- **Environment:** local sessions, signing keys, and access tokens.
- **Relay client:** exposes only the validated loopback HTTP server.
- **Remote client:** retains the DPOP private key and environment token.

The relay remains a trusted mint broker because it holds the cloud-mint signing key. DPOP limits credential reuse but does not neutralize compromise of that authority.

Current Topology



Steady-state HTTP and WebSocket traffic goes directly from the remote client through the managed endpoint. The relay handles sparse health and bootstrap requests, not the active session data path.

Authentication Boundaries

BOUNDARY	AUTHENTICATION	PURPOSE
Client → relay link management	Clerk bearer / CLI OAuth	Create, list, or remove links.
Client → protected relay APIs	Relay DPOP token + proof	Status, connect, and mobile registration.
Relay → environment	Short-lived relay-signed JWT	Signed health and credential-mint requests.
Client → environment	Environment token + DPOP	Normal HTTPS APIs and WSS ticket issuance.
Environment → relay	Environment bearer + signed proof	Publish redacted agent activity.

Link, Bootstrap, and Operate

Every workflow preserves local authority while making cloud coordination retry-safe and suitable for desktop, mobile, and headless use.

1. Link a Local Environment

Authenticate

Desktop/mobile uses a Clerk bearer. CLI uses browser PKCE and persists desired link state.

Prove locally

Relay issues a short-lived challenge. The local environment validates loopback origin and signs it.

Reconcile

Relay verifies proof and capabilities, then creates or reuses the tunnel, ingress, and CNAME.

Activate

Relay returns endpoint config and connector token. Environment persists config and starts the relay client.

The local proof endpoint requires `relay:write`, rejects forwarded authority headers, and atomically persists the environment key pair.

2. Remote Connection Bootstrap

Proof key

Client creates a DPoP key and exchanges its Clerk JWT for a relay DPoP access token.

Mint request

Client calls connect. Relay sends an audience-bound, short-lived signed proof to the managed endpoint.

Local issue

Environment validates user, scope, lifetime, nonce, and DPoP thumbprint, then returns a signed bootstrap credential.

Direct session

Client redeems locally for an environment token, gets a one-time WSS ticket, and opens the WebSocket.

The relay validates the environment response signature, nonce, endpoint, and DPoP binding before returning bootstrap data to the client.

Managed Endpoint Lifecycle

1. Reserve deterministic hostname and tunnel name for `(userId, environmentId)`.
2. Reuse or create the named tunnel; rewrite ingress to the validated loopback origin.
3. Reconcile CNAME records and remove duplicates; recover safely from create conflicts.
4. Mark ready only after resource IDs and namespace checks are persisted.

Unlink Cleanup

- Delete managed DNS and tunnel resources.
- Remove the allocation and revoke the user link.
- Revoke publication credentials after the final active link disappears.
- Stop the local relay client and clear persisted relay configuration.
- Retain checkpoints when teardown fails so cleanup can be retried.

3. Agent Activity Notifications

Project

Environment creates a narrow publishable thread state and redacts/caps failure details.

Sign

Environment posts with its bearer credential and a per-state signed proof.

Persist

Relay checks credential, signature, scope, expiry, and nonce, then stores current state.

Deliver

Queue workers send push notifications or Live Activity updates through APNs.

Hardening and Deployment Contract

The design constrains tunnel origins, proof audiences, egress destinations, redirects, credential exposure, and teardown behavior.

SSRF and Tunnel Controls

RISK	IMPLEMENTED CONTROL
Arbitrary tunnel upstream	Both sides accept managed origins only for loopback hosts and valid ports.
Forwarded-origin confusion	Link proof requires the exact loopback URL and rejects forwarded host/protocol headers.
Stored endpoint replacement	Status/connect resolve ready allocations from Postgres and require the managed DNS namespace.
Redirected relay egress	Relay health and mint requests use manual redirect handling.
Impersonated tunnel backend	Relay verifies signed environment responses, nonce, and request binding.
Stolen access token replay	Relay and environment tokens require DPoP proofs and replay guards.
Connector token exposure	Relay client is spawned without a shell and receives the token in <code>TUNNEL_TOKEN</code> .

Credential Ownership

- Environment Ed25519 private key stays local.
- Cloud-mint private key stays in hosted relay config; only its public key is installed locally.
- Relay environment bearer is hashed in Postgres and stored plaintext only locally.
- Remote DPoP private keys and environment access tokens remain client-side.
- WebSocket tickets are short-lived and one-time.

Operational Profile

- One named tunnel and DNS record per active user/environment allocation.
- HTTPS request/response and WSS only; no arbitrary TCP exposure.
- Relay traffic is limited to health and bootstrap control calls.
- Active sessions are interactive and WebSocket-heavy; inactive links are nearly idle.
- Dedicated registrable tunnel domain and Public Suffix List entry are required before broad untrusted use.

Deployment and Runtime

LAYER	CONTRACT
Relay	Cloudflare Worker, tunnel/DNS bindings, Hyperdrive, PlanetScale Postgres, APNs queue + DLQ, replay-row pruning cron, and Axiom OTLP traces.
Environment	Loopback server, atomic secret store, relay-client lifecycle, signed health/mint responses, OAuth exchange, and WebSocket tickets.
Clients	Secure relay URL, Clerk configuration, DPoP key management, environment token storage, and direct managed-endpoint traffic.

Release Gate

Identity

Keep private signing keys in their owning trust domain. Validate issuer, audience, scope, expiry, nonce, and proof-key binding.

Network

Permit loopback tunnel origins only. Resolve relay egress from ready allocations and disable redirects.

Lifecycle

Make provisioning idempotent, preserve failed-cleanup checkpoints, and revoke shared credentials only after the final link disappears.

Standards basis: RFC 8252 for native-app OAuth, RFC 8693 for token exchange, and RFC 9449 for DPoP proof of possession.